

INCIDENT RESPONSE & LEGAL COMPLIANCE

WEEK 1

Legal & Regulatory Landscape





AGENDA

- Introduction: today's cyber-threat environment
- Regulatory landscape overview
- Key U.S. cybersecurity regulations
- EU & international frameworks
- Implications for incident response planning
- conclusion



INTRODUCTION

TODAY'S CYBER-THREAT ENVIRONMENT

- Rapid rise of ransomware, APTs & state-sponsored actors
- “Perfect storm”: technical breach + complex notification duties
- New normal: simultaneous incident handling and compliance decisions



REGULATORY RESPONSE TO ESCALATING THREATS

- SEC: 4-day material-impact disclosure rule
- GDPR: up to 4 % of global revenue in fines
- DORA (EU Finance): 24-hour initial notification, hefty penalties
- Industry standards (ISO/IEC 27001) as de facto requirements



THREE CRITICAL COMPLIANCE DOMAINS



Detection Protocols

Mandated monitoring & early-warning controls



Reporting Mechanisms

Multi-body notification matrices with overlapping timelines



Remediation Standards

Technical requirements for containment, eradication & recovery



U.S. REGULATORY ARCHITECTURE

- **FISMA & NIST SP 800-61/800-53:** risk-based controls + incident handling
- **SEC Disclosure Rules:** public companies → report material incidents within 4 business days
- **PPD-41:** federal coordination blueprint for major cyber events



SECTOR-SPECIFIC U.S. RULES

- **HIPAA/HITECH (Healthcare)**
 - tough security standards like HIPAA and HITECH
 - Formalized IR plans & MFA requirements
- **CIRCA (Critical Infrastructure)**
 - Tailored reporting for utilities, energy, transportation
- **DORA (Financial Services)**
 - 24-hour initial report + comprehensive resilience obligations



EU & INTERNATIONAL FRAMEWORKS

GDPR

- 72-hour personal-data breach notification – One of the strictest globally

DORA

- Financial institutions and their technology partners
- Standardized incident reporting protocols

ISO/IEC 27001

- Technically voluntary, but globally respected ISM benchmark



IMPLICATIONS FOR IR PLANNING

Timely & Accurate Reporting

- Align workflows with divergent timelines

Evidence Preservation & Forensics

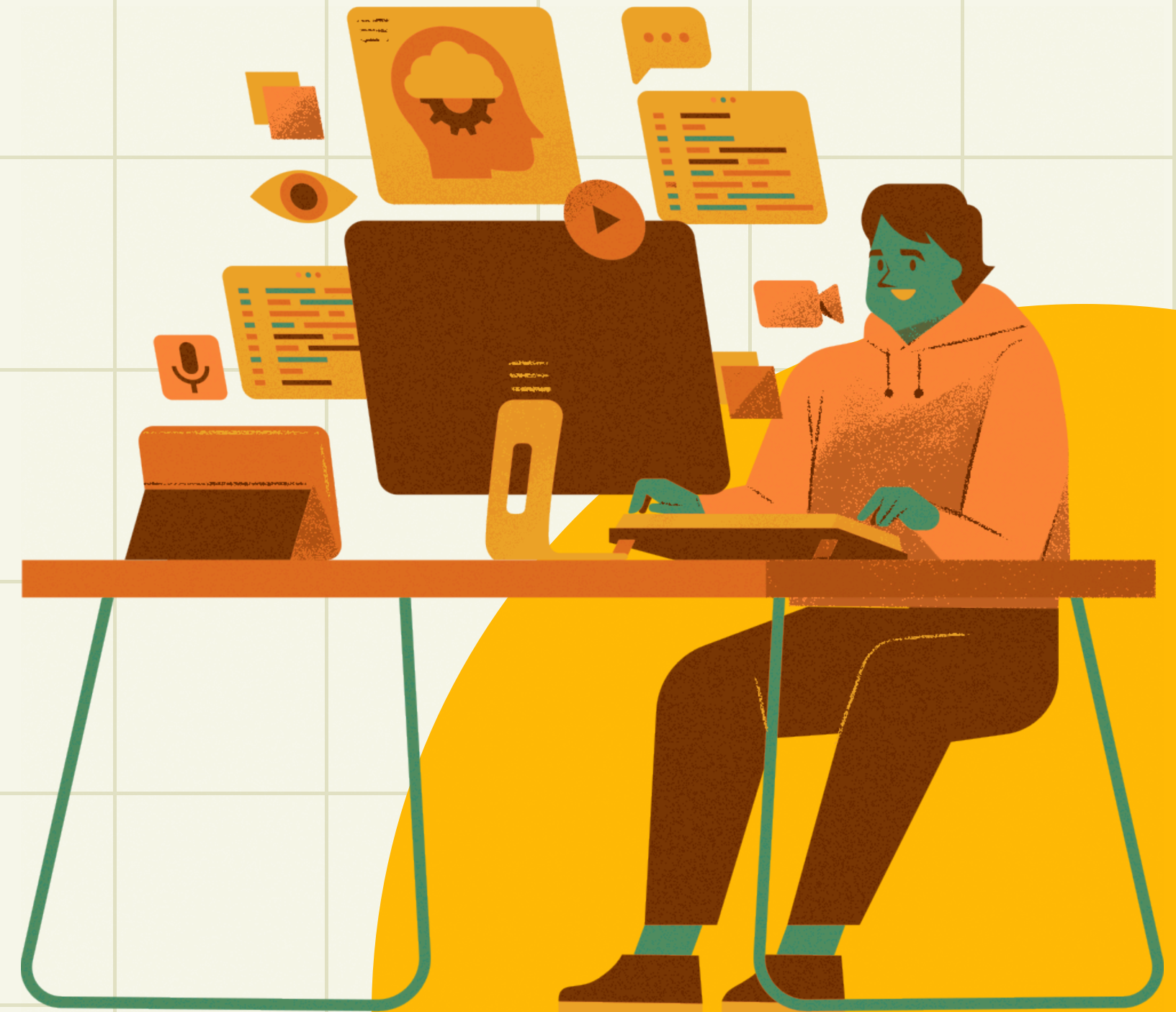
- Follow NIST guidelines to align with legal and forensic standards.

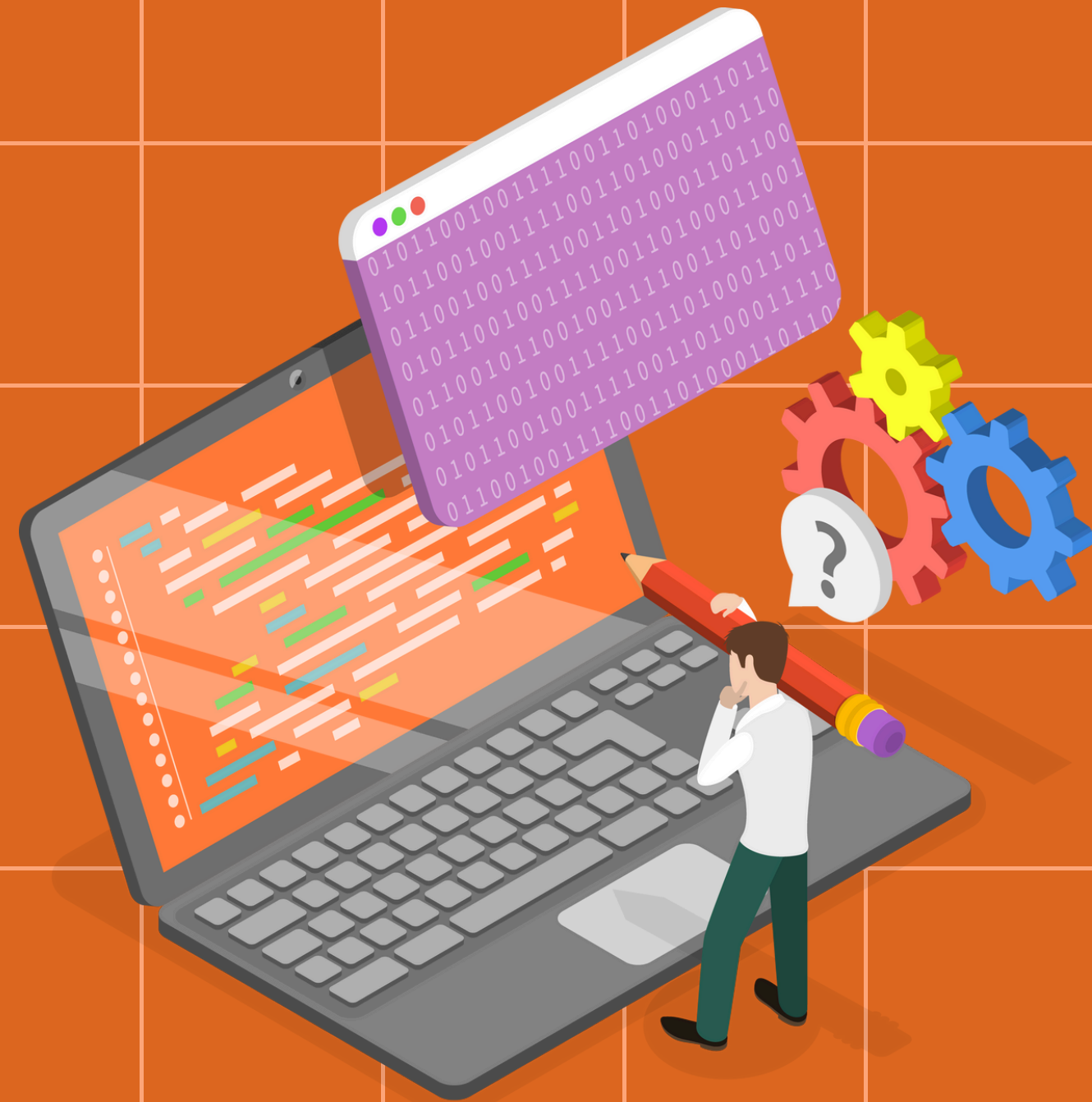
Interagency & Cross-Sector Coordination

- PPD-41 & sector-specific liaison make that cooperation smooth and efficient.

Continuous Monitoring & Testing

- Quarterly tabletop exercises validating technical & compliance readiness





CONCLUSION AND STRATEGIC IMPERATIVES

- Establishing Cross-Functional Governance
- Implementing Regular Simulation Exercises
- Fostering Collaborative Intelligence Sharing:
- Prepare for Week 2: Deep dive into Incident Detection Protocols and tabletop design

MEET THE TEAM

MARIAM EID

ALI ELSABAGH

ZEYAD AYMAN

Team Leader

MAHMOUD SALMAN

MAHMOUD ALI



THANK YOU

